

1)As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain tesla.com using theHarvester in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendation.

Aim

To perform an Open Source Intelligence (OSINT) assessment on the target domain **tesla.com** using theHarvester in Kali Linux to identify publicly available email addresses, subdomains, hosts, and IP addresses, and analyze the associated security risks.

Objective

- Enumerate publicly available email addresses.
 - Discover subdomains.
 - Identify hosts.
 - Collect IP addresses.
 - Categorize discovered email addresses.
 - Analyze reconnaissance risks.
 - Recommend security countermeasures.
-

Tool Used

- Kali Linux
 - theHarvester
-

Command Executed

Basic Search

```
theHarvester -d tesla.com -b all
```

Save Results

```
theHarvester -d tesla.com -b all -f tesla_report
```

Search Using Bing Only

```
theHarvester -d tesla.com -b bing
```

Search Using CRT.sh

```
theHarvester -d tesla.com -b crtsh
```

Search Using SecurityTrails

```
theHarvester -d tesla.com -b securityTrails
```

Findings

Domain

tesla.com

Public Email Addresses)

Example Format

Email Address	Possible Role
support@tesla.com	Customer Support
sales@tesla.com	Sales Team
hr@tesla.com	Human Resources
careers@tesla.com	Recruitment

Email Address	Possible Role
admin@tesla.com	Administration
webmaster@tesla.com	Technical Team
security@tesla.com	Security Team

Discovered Subdomains

Example

www.tesla.com

shop.tesla.com

careers.tesla.com

auth.tesla.com

developer.tesla.com

energy.tesla.com

Hosts

Example

www.tesla.com

mail.tesla.com

vpn.tesla.com

IP Addresses

Example

23.xxx.xxx.xxx

104.xxx.xxx.xxx

Categorization of Email Addresses

Category	Example
Support	support@tesla.com
Sales	sales@tesla.com
Human Resources	hr@tesla.com
Administration	admin@tesla.com
Technical Team	webmaster@tesla.com
Security	security@tesla.com

Risk Analysis

1. Reconnaissance

An attacker can gather valuable information about the organization before launching an attack. Public email addresses, subdomains, hosts, and IP addresses reveal the company's infrastructure and personnel.

2. Spear-Phishing

Attackers can craft highly targeted phishing emails using discovered employee email addresses.

Example:

Dear HR Team,

Please review the attached employee payroll update.

Regards,

Finance Department

Because the attacker knows valid email addresses, the phishing email appears more legitimate.

3. Credential Harvesting

Attackers may create fake Tesla login pages and send links to employees.

Example:

<https://tesla-security-login.com>

Victims enter their usernames and passwords, which are then stolen.

4. Impersonation Attack

An attacker may impersonate an executive or administrator.

Example

From:

admin@tesla.com

Victims may trust the email and disclose confidential information.

5. Infrastructure Mapping

Subdomains and hosts reveal:

- VPN servers
- Mail servers
- Development servers
- Authentication portals
- Internal applications

These become potential attack targets.

Impact

Information gathered through OSINT significantly increases the success rate of social engineering attacks because attackers possess accurate organizational details.

Potential impacts include:

- Data theft
- Credential compromise
- Business Email Compromise (BEC)

- Malware delivery
 - Financial fraud
 - Unauthorized access
-

Countermeasures

1. Limit Public Exposure

Avoid publishing unnecessary employee email addresses on public websites.

2. Use Generic Contact Emails

Instead of

john.smith@company.com

Use

support@company.com

or

contact@company.com

3. Security Awareness Training

Educate employees about:

- Phishing
 - Spear-phishing
 - Social engineering
 - Fake login pages
-

4. Enable Multi-Factor Authentication (MFA)

Even if credentials are stolen, attackers cannot easily access accounts without the second authentication factor.

5. Email Authentication

Implement:

- SPF
- DKIM
- DMARC

These technologies reduce email spoofing and impersonation attacks.

6. Monitor Public Information

Regularly perform OSINT scans on the organization's own domain to identify and remove unnecessary publicly exposed information.

7. Restrict Employee Information

Avoid exposing organizational charts, staff directories, or detailed employee information publicly unless necessary.

Result

TheHarvester successfully collected publicly available information related to **tesla.com**, including email addresses, subdomains, hosts, and IP addresses. The assessment demonstrated how OSINT can assist attackers during the reconnaissance phase by enabling spear-phishing, credential harvesting, and impersonation attacks. Implementing appropriate security controls such as limiting public information, using MFA, deploying SPF/DKIM/DMARC, and conducting employee awareness training can significantly reduce the risk of social engineering attacks.

Commands Summary

Basic Enumeration

```
theHarvester -d tesla.com -b all
```

Save Report

```
theHarvester -d tesla.com -b all -f tesla_report
```

Bing Search

```
theHarvester -d tesla.com -b bing
```

```
# CRT.sh Search
```

```
theHarvester -d tesla.com -b crtsh
```

```
# SecurityTrails Search
```

```
theHarvester -d tesla.com -b securityTrails
```

2) As a cybersecurity awareness consultant, you are required to conduct a phishing awareness simulation using GoPhish and dummy employee accounts provided in the lab. Create an email template, launch a campaign, monitor user interactions, and generate a report showing delivery rate, email open rate, and click rate. Based on the results, provide recommendations to improve user awareness against phishing attacks.

Aim

To conduct a phishing awareness simulation using **GoPhish** by creating a phishing email template, launching a campaign with dummy employee accounts, monitoring user interactions, generating a phishing awareness report, and recommending security measures to improve user awareness against phishing attacks.

Tools Required

- Kali Linux
- GoPhish
- Web Browser (Firefox)
- Dummy Employee Accounts
- Mailtrap SMTP (or Gmail SMTP for testing)

Commands Executed

Navigate to GoPhish Directory

```
cd ~/Downloads
```

Start GoPhish

./gophish

Open GoPhish Dashboard

<https://127.0.0.1:3333>

Login

Username

admin

Password

(Password generated by GoPhish terminal)

Procedure

Step 1: Create an Email Template

Go to:

Email Templates → New Template

Fill the details:

Template Name

Password Reset Notification

Subject

Your Company Password Will Expire Today

HTML Email Body

<html>

<body>

<p>Dear {{.FirstName}},</p>

<p>Your company password is scheduled to expire today.</p>

<p>Please click the link below to reset your password.</p>

<p>

Reset My Password

</p>

<p>If you have already updated your password, please ignore this email.</p>

<p>

Regards,

IT Support Team

</p>

</body>

</html>

Click **Save Template**.

Step 2: Create a Landing Page

Go to

Landing Pages → New Page

Name

Password Reset Page

Create a login page containing:

- Username
- Password
- Login Button

Enable

Capture Submitted Data

Click

Save Page

Step 3: Create a Sending Profile

Go to

Sending Profiles → New Profile

Example configuration

Field	Value
Profile Name	Mailtrap
Interface Type	SMTP
SMTP From	IT Support itsupport@company.com
SMTP Host	sandbox.smtp.mailtrap.io
Port	587
Username	Mailtrap Username
Password	Mailtrap Password

Click

Save Profile

Step 4: Create Dummy Employee Accounts

Go to

Users & Groups → New Group

Group Name

Employees

Example Employee List

First Name	Last Name	Email	Position
John	Smith	john@example.com	Employee
Alice	Brown	alice@example.com	HR
David	Wilson	david@example.com	Sales

Save the group.

Step 5: Launch the Campaign

Go to

Campaigns → New Campaign

Fill the details

Campaign Name

Phishing Awareness Simulation

Select

- Email Template
- Landing Page
- Sending Profile
- Employee Group

Click

Launch Campaign

Step 6: Monitor User Interaction

Open

Campaigns

Select the campaign.

Monitor:

- Emails Delivered
- Emails Opened
- Links Clicked
- Credentials Submitted (if enabled)

Sample Campaign Report

Metric	Value
Emails Sent	10
Successfully Delivered	10
Delivery Rate	100%
Emails Opened	8
Open Rate	80%
Link Clicks	5
Click Rate	50%
Credentials Submitted	2

Report Analysis

Delivery Rate

100% of emails were successfully delivered to the recipients.

Email Open Rate

80% of employees opened the phishing email, indicating that the email appeared convincing.

Click Rate

50% of employees clicked the phishing link, demonstrating susceptibility to phishing attacks.

Credential Submission

Two employees entered credentials on the simulated phishing page, indicating a high risk of credential compromise.

Risk Analysis

The phishing simulation demonstrates how attackers exploit human behavior rather than technical vulnerabilities.

Spear-Phishing

Attackers create personalized emails that appear to originate from trusted departments such as IT Support or Human Resources.

Credential Harvesting

Victims are redirected to fake login pages where usernames and passwords are collected.

Business Email Compromise (BEC)

Compromised employee credentials may allow attackers to impersonate staff members and gain unauthorized access to organizational resources.

Data Breach

Successful phishing attacks can expose confidential information, customer records, and financial data.

Social Engineering

Attackers exploit trust, urgency, and authority to persuade users to click malicious links or disclose sensitive information.

Result

A phishing awareness simulation was successfully conducted using GoPhish. The campaign simulated a realistic phishing attack by sending emails to dummy employee accounts, tracking email delivery, open rates, and click rates. The results highlighted user susceptibility to phishing attacks and demonstrated the importance of continuous security awareness training, email authentication mechanisms, and strong organizational security policies to reduce phishing-related risks.

3) Using Nmap Aggressive Scan (-A) on scanme.nmap.org, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.

Aim

To perform an aggressive scan on **scanme.nmap.org** using Nmap, identify the target's operating system, open ports, and service versions, analyze how an attacker could use the collected information for a social engineering attack against the IT support team, and recommend appropriate defensive measures.

Tool Required

- Kali Linux
 - Nmap
-

Command Executed

Aggressive Scan

```
nmap -A scanme.nmap.org
```

Sample Output

Note: The exact output may vary depending on when the scan is performed.

Port	State	Service	Version
22/tcp	Open	SSH	OpenSSH
80/tcp	Open	HTTP	Apache HTTP Server
9929/tcp	Open	NPING Echo	Nmap Service

Port	State	Service	Version
31337/tcp	Open	Elite	Custom Service

Operating System Detection

Linux Operating System

Service Detection

SSH Server

Apache Web Server

Nmap Nping Echo Service

Traceroute

Traceroute completed successfully.

Host Status

Host is up.

Findings

The aggressive scan successfully identified:

- Target operating system
- Open TCP ports
- Running services
- Service versions
- Network route information

This information helps understand the target's exposed services and network configuration.

Attack Methodology (Assuming an Attacker)

An attacker could use the information gathered during reconnaissance to conduct a targeted **social engineering attack** against the IT support team.

Step 1 – Reconnaissance

Using Nmap, the attacker identifies:

- Linux operating system
 - SSH service
 - Apache web server
 - Open ports and running services
-

Step 2 – Collect Public Information

The attacker gathers publicly available information such as:

- Employee names
- IT support email addresses
- Organization structure
- Helpdesk contact information

using OSINT techniques.

Step 3 – Create a Believable Scenario

Since the scan reveals that the organization uses Linux servers and SSH, the attacker may send an email claiming:

"Critical SSH security update required."

or

"Apache Web Server vulnerability detected."

The email appears legitimate because it references technologies actually used by the organization.

Step 4 – Phishing Email

Example:

Subject

Urgent Security Patch Required for Apache Server

Email Body

Dear IT Team,

A critical vulnerability has been detected in your Apache web server.

Please verify your administrator account immediately using the secure portal below.

<https://company-security-update.example>

Regards,

Network Security Team

Step 5 – Credential Harvesting

The fake website requests:

- Username
- Password

The attacker captures these credentials if the victim enters them.

Step 6 – Impersonation

After obtaining credentials, the attacker may:

- Access internal systems
 - Send emails pretending to be IT support
 - Request confidential information
 - Launch additional phishing campaigns
-

Risk Analysis

The aggressive scan itself does not exploit the target, but it reveals valuable information that can assist attackers.

Risks Identified

- Operating system disclosure
 - Service version disclosure
 - Open ports visible
 - Technology stack exposed
 - Easier creation of convincing phishing emails
 - Increased likelihood of successful social engineering attacks
-

Defensive Recommendations

1. Limit Information Disclosure

Avoid exposing unnecessary service banners and software version information.

2. Apply Regular Security Updates

Keep operating systems and applications updated with the latest security patches.

3. Conduct Security Awareness Training

Educate employees about phishing, spear-phishing, and social engineering attacks.

4. Enable Multi-Factor Authentication (MFA)

Require MFA for administrative and remote access accounts.

5. Restrict Open Ports

Close unused ports and services using firewall rules.

6. Deploy Intrusion Detection Systems (IDS)

Monitor suspicious scanning activities using IDS/IPS solutions.

7. Verify IT Communications

Employees should confirm unexpected IT requests through official communication channels before taking action.

Result

An aggressive Nmap scan was successfully performed on **scanme.nmap.org** using the -A option. The scan identified the target's operating system, open ports, running services, and service versions. The collected information demonstrates how attackers can leverage reconnaissance data to craft convincing social engineering attacks targeting IT support personnel. Implementing proper security controls, minimizing information disclosure, and conducting regular security awareness training can significantly reduce the risk of successful attacks.